

Exercício 7 — CWEs Comuns

Forneça exemplos de CWEs comuns e seu potencial impacto na segurança de software.

Como você priorizaria a resolução dessas fraquezas em um projeto de desenvolvimento de software?

7. CWEs Comuns

Exemplos de CWEs Comuns e seu Impacto

CWE	Fraqueza	Impacto Real
CWE-79	Cross-Site Scripting (XSS)	Invasor executa scripts maliciosos no navegador da vítima — rouba sessões, redireciona usuários
CWE-89	Injeção de SQL	Invasor lê, modifica ou exclui todo o banco de dados
CWE-22	Travessia de Caminho	Invasor acessa arquivos fora do diretório pretendido (ex: <code>/etc/passwd</code>)
CWE-787	Escrita Fora dos Limites	Corrompe memória — pode levar a travamentos ou execução completa de código
CWE-306	Autenticação Ausente	Funções críticas expostas sem necessidade de login
CWE-502	Desserialização de Dados Não Confiáveis	Invasor envia um objeto manipulado que executa código no servidor
CWE-20	Validação Inadequada de Entrada	A causa raiz por trás da maioria dos ataques de injeção
CWE-798	Credenciais Codificadas	Senhas enterradas no código-fonte — expostas quando o repositório vaza

Conexão com o Mundo Real

```
CWE-89 (Injeção de SQL)    → CVE-2012-1823 (PHP-CGI)    → milhões de
servidores expostos
CWE-79 (XSS)               → CVE-2021-39141 (Spring)    → sequestro de sessão
em escala
CWE-502 (Desserialização)  → CVE-2017-9805 (Apache Struts) → violação Equifax
(147M registros)
```

Toda CVE tem uma CWE por trás. Corrija o padrão CWE — previna a CVE.

Como Priorizar em um Projeto de Software

Passo 1 — Comece pelo CWE Top 25

O **CWE Top 25** é atualizado anualmente e classifica as fraquezas por frequência e severidade. Comece por aí. Estas são as causas raiz mais comuns de violações reais.

Passo 2 — Pontue pelo impacto no seu contexto

Faça três perguntas para cada CWE encontrado:

Pergunta	Peso
Pode ser explorado remotamente?	Alta prioridade se sim
Expõe dados sensíveis ou permite execução de código?	Alta prioridade se sim
O componente afetado está voltado para a internet?	Alta prioridade se sim

Passo 3 — Ordem de Correção

```
1º → CWE-89, CWE-79, CWE-306  (injeção + autenticação ausente = risco imediato)
2º → CWE-502, CWE-22, CWE-787 (complexos, mas de impacto crítico)
3º → CWE-20, CWE-798          (fundamentais – corrija-los previne problemas
futuros)
```

Passo 4 — Desloque a Segurança para a Esquerda

Não espere os testes para encontrar CWEs. Use **ferramentas SAST durante o desenvolvimento** para que fraquezas sejam detectadas antes de chegarem ao código base.

Fase	Ação
Design	Modelagem de ameaças com base no CWE Top 25
Codificação	Aplicar padrões seguros (consultas parametrizadas, validação de entrada)
Revisão de Código	Sinalizar violações CWE com IDs específicos
Pipeline CI/CD	Bloquear merge se CWEs críticos forem detectados pelo SAST

Resumo

Os CWEs mais perigosos são aqueles que os desenvolvedores escrevem sem perceber. Priorize por explorabilidade e impacto — depois corrija a causa raiz, não apenas o sintoma.